

IoT Security Capstone

Experiment Results, Insights & Recommendations

Kayla Colletti May 2026

The Threat: Unprotected IoT Pipelines

What happens when MQTT messages travel without protection?

Eavesdrop

If MQTT traffic is not properly secured, an attacker on the same network may be able to intercept sensor data as it travels between devices. This can expose operational information such as pressure levels, flow rates, and device activity, giving attackers insight into how the water system operates and helping them prepare future attacks.

Inject Fake Data

An attacker may try to send fake sensor readings to the broker. If the system accepts these messages as legitimate, it could display inaccurate data, trigger improper actions, or conceal actual issues within the system.

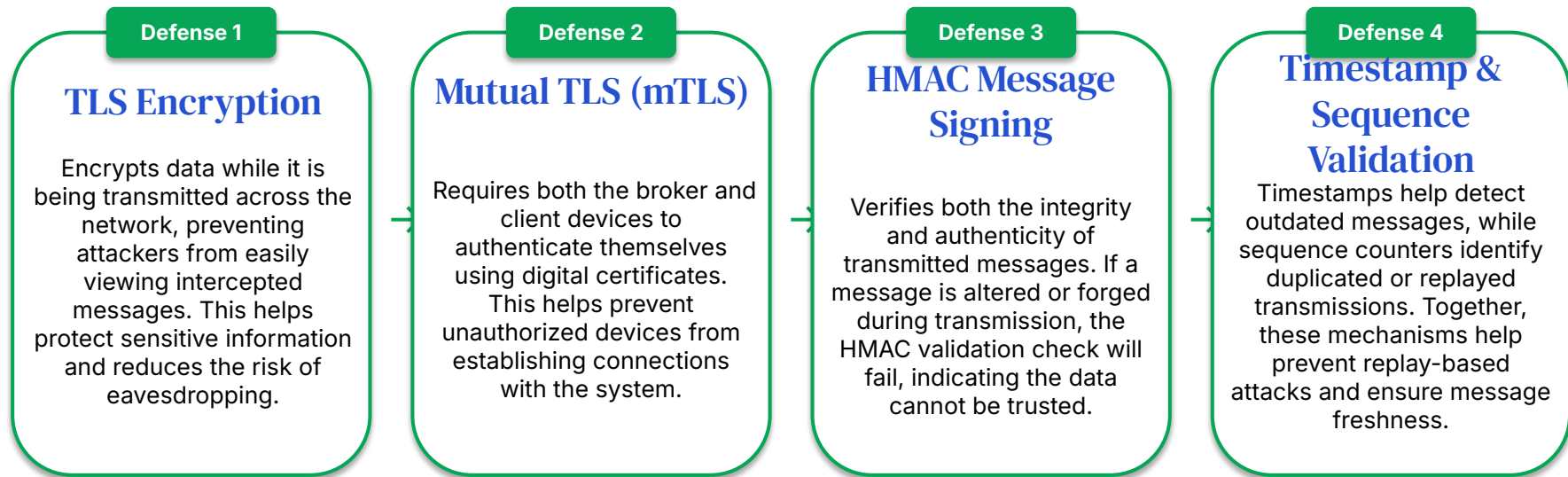
Replay Attack

A replay attack occurs when an attacker intercepts a legitimate message and retransmits it at a later time. Although the message was originally authentic, reusing it can cause the system to process outdated or repeated data, potentially leading to incorrect behavior or decisions.

Unprotected IoT pipelines are vulnerable because attackers can observe traffic, forge messages, or replay captured data. Without layered validation and security controls, the system cannot reliably distinguish trusted data from malicious traffic.

Defense Architecture: Four Layers of Protection

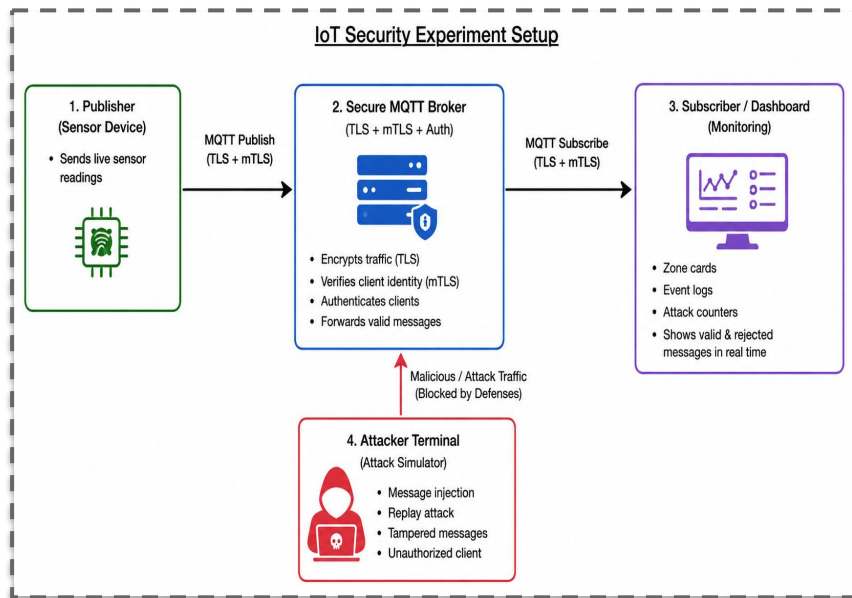
Each layer catches what the previous one can't.



No single defense is enough. TLS keeps data private, mTLS checks device identity, HMAC catches if messages are changed or fake, and timestamps with sequence numbers block replay attacks. If you take even one of these away, you open up a gap attackers can take advantage of.

Experiment Setup: Three-Phase Attack Simulator

A controlled test against the live pipeline to verify every defense works.



Your Setup Process

- I started the secure MQTT broker with TLS, mTLS, and authentication enabled.
- I launched the subscriber/dashboard so I could monitor real-time data, including valid and rejected messages as they came through.
- I ran the secure publisher to send live sensor readings into the pipeline.
- I opened the dashboard in the browser to track zone cards, event logs, and attack counters.
- Then I opened a separate attacker terminal and ran the attack simulator.
- During the test, I watched both the terminal output and the live dashboard to see exactly which defenses caught and blocked each stage of the attack.

Attack Results: Every Attack Blocked

Which defense caught each attack phase — and why it works.

Attack Phase	What the Attacker Tried	Defense That Caught It	Why It Works
Phase 1: Eavesdrop	Intercept traffic and observed legitimate messages.	There was no direct rejection, however encrypted transport and layered protections limited useful exploitation.	Observation alone did not allow unauthorized control or message acceptance.
Phase 2: Inject	Sent fake sensor data with an invalid HMAC.	HMAC validation	The subscriber rejected the forged message since the signature did not match the shared secret.
Phase 3: Replay	Re-sent a previously captured legitimate message.	Sequence tracking and/or timestamp validation.	The subscriber detected that the message was stale/ duplicated and rejected it.



Result: 0 attacks succeeded | 100% blocked

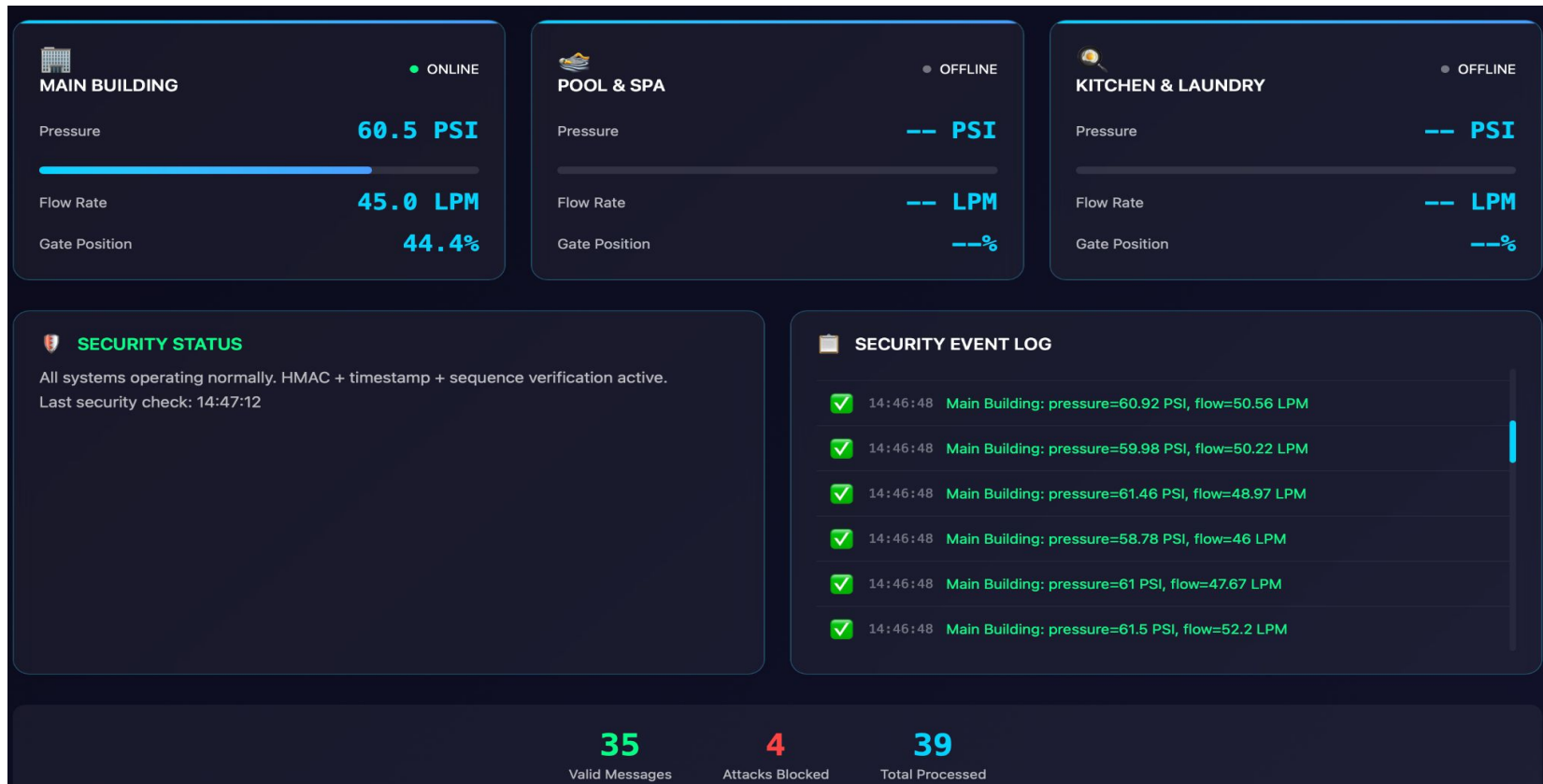
Dashboard: Attack Detected

Red alerts, shaking zone cards — every attack caught in real time.

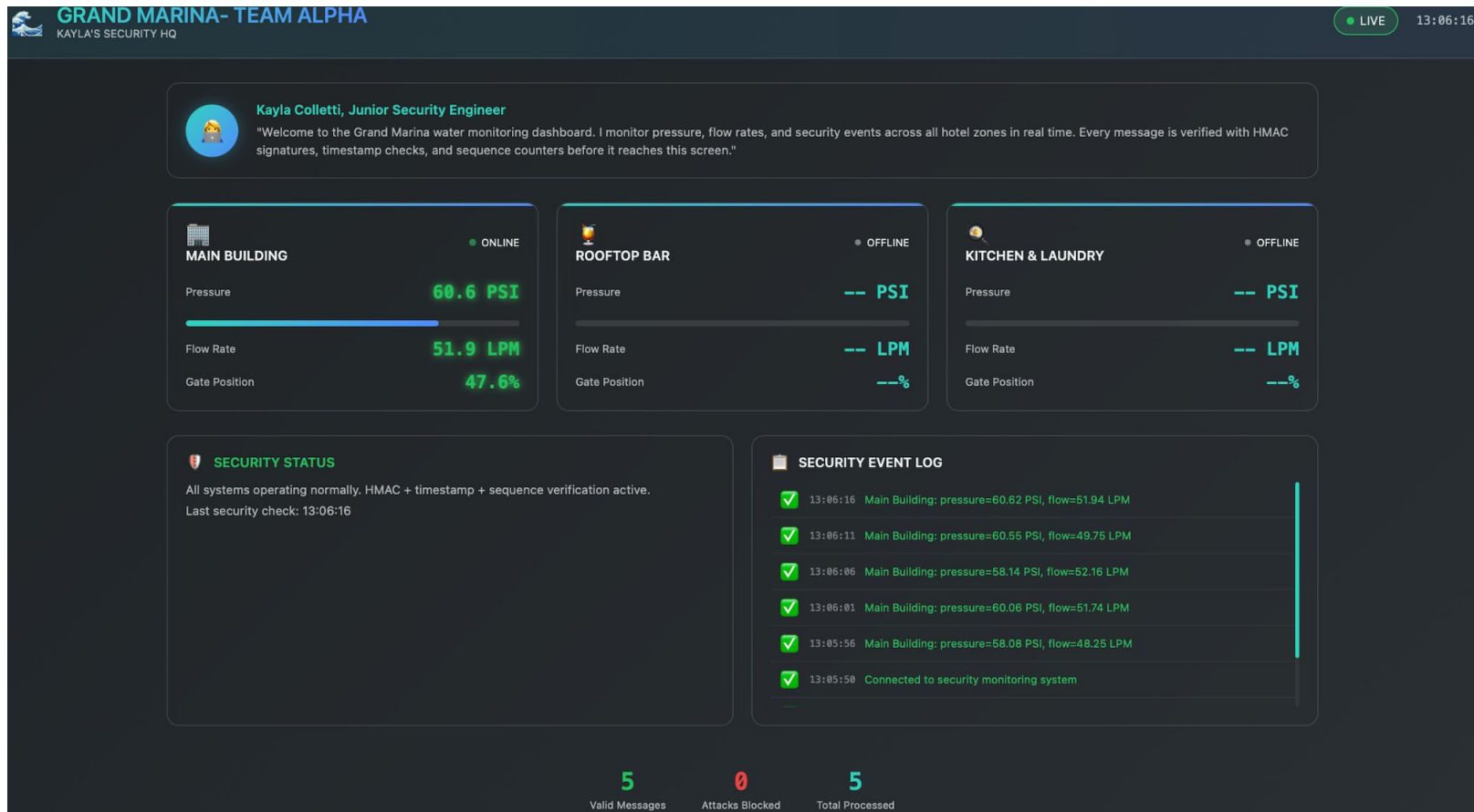


Stats: Attacks Blocked

The numbers tell the story — every attack rejected, every valid message accepted.



Custom Dashboard: Making It Mine



Key Insights

What this experiment revealed about IoT security.

1

No single defense is enough

mTLS stops outsiders but not compromised insiders. HMAC stops forgeries but not replays. You need all layers working together.

2

Secure connections do not guarantee valid messages

Securing the connection alone is not enough. Each message still needs to be validated for integrity, freshness, and uniqueness to ensure it has not been altered, reused, or tampered with.

3

Replay attacks can be harder to detect than expected

Replay attacks are more realistic than they seem and are often easy to underestimate. A repeated message can appear valid unless the system verifies timestamps and sequence numbers.

4

Security and usability can work together

The system maintained live monitoring and usable dashboard while still detecting and blocking attacks.

Recommendations for Grand Marina

What should happen next to secure the IoT infrastructure at scale.

1

Strengthen Device Authentication

Grand Marina should ensure every IoT device has a unique identity using certificate-based authentication like mTLS. This helps prevent unauthorized devices from connecting to the broker. Message validation should also be enforced to protect against spoofing and replay attacks.

2

Improve IoT Security Policies

They should adopt a strict onboarding policy where no device is trusted by default. Devices must pass security checks like approved firmware, valid certificates, and secure configuration before joining the network. Regular key and certificate rotation should also be required.

3

Add Centralized Monitoring and Detection

A SIEM (Security Information and Event Management) system should be used to collect and analyze logs from all IoT devices and brokers. It acts as a central security dashboard that watches everything at once across the network. This helps detect unusual patterns like repeated messages, failed logins, or abnormal device behavior in real time. MQTT-specific intrusion detection can also be added to improve visibility into attacks.

4

Use Layered Security Design

Security should be implemented in layers, not as a single control point. Even with a secure connection, message integrity and freshness checks are still necessary. Combining authentication, encryption, validation, and monitoring creates a stronger overall defense.

Questions?
